

 **RISK ASSESSMENT — FAST Accounting & Finance
(AnF) Department**

Version: 1.0

Scope: FAST-NUCES Islamabad Campus — Accounting &
Finance Department**

◆ Risk Matrix (5 × 5 Standard)

Likelihood Scale

Value	Description
1	Rare
2	Unlikely
3	Possible
4	Likely
5	Almost Certain

Impact Scale

Value	Description
1	Negligible
2	Minor disruption
3	Moderate disruption
4	Major financial/operational damage
5	Critical loss, legal/audit failure

Risk Score = Likelihood × Impact

Score Range	Risk Level
1-5	Low
6-10	Medium
12-15	High
16-25	Critical

 RISK ASSESSMENT TABLE

Risk ID	Asset	Threat	Vulnerability	Likelihood	Impact	Score	Risk Level	Existing Controls	Recommended Treatment	Annex A Controls
RA-01	Financial ERP	Unauthorized access	Weak MFA & password reuse	4	5	20	Critical	Basic passwords	Implement MFA, strong password policy, RBAC	A.5.17, A.8.2, A.9.4
RA-02	Payroll Records	Data leakage	Unencrypted files	3	5	15	High	Limited access	Encrypt payroll data, enable DLP	A.8.24, A.8.28
RA-03	Staff Email	Phishing attack	User unawareness	5	4	20	Critical	Spam filter	Phishing training, email scanning	A.6.3, A.8.12
RA-04	Workstations	Ransomware	Outdated OS patches	4	5	20	Critical	Antivirus	Patch management, remove admin rights	A.8.7, A.5.23
RA-05	NAS Backup	Backup failure	No restore testing	3	5	15	High	Auto backups	Quarterly restore drills	A.5.30, A.8.13
RA-06	Cloud ERP	Service outage	Vendor downtime	3	4	12	High	SLA only	Offline contingency workflow	A.5.29
RA-07	Vendor Database	Invoice fraud	Weak vendor verification	3	4	12	High	Manual checks	2-step vendor verification, segregation of duties	A.5.20, A.8.9
RA-08	Budget Data	Insider manipulation	No audit logs	2	5	10	Medium	Partial ERP logs	Enable full audit logging	A.8.16

Risk ID	Asset	Threat	Vulnerability	Likelihood	Impact	Score	Risk Level	Existing Controls	Recommended Treatment	Annex A Controls
RA-09	Laptops	Physical theft	No disk encryption	3	5	15	High	Cable lock	Enable BitLocker/device encryption	A.8.11, A.7.4
RA-10	Network Switch	Network outage	Unsecured configuration	2	4	8	Medium	Password protected	Harden configuration, backup configs	A.8.9
RA-11	Finance Wi-Fi	Unauthorized access	Weak Wi-Fi password	3	4	12	High	WPA2	Enforce WPA3, MAC filtering	A.8.20
RA-12	File Cabinet	Loss of physical documents	No offsite backup	2	4	8	Medium	Lockable cabinets	Digitize & securely store documents	A.7.4
RA-13	ERP Accounts	Brute force attack	No lockout policy	4	3	12	High	Basic authentication	Enable lockout after failed attempts	A.8.23
RA-14	Bank Reconciliation	Payment error	Manual spreadsheets	3	3	9	Medium	Manual review	Implement dual-control & verification	A.5.20
RA-15	OneDrive Finance	Cloud misconfiguration	Public link exposure	3	4	12	High	Limited sharing	Enforce “internal only” sharing	A.8.11
RA-16	End-user PCs	Data exfiltration	USB ports enabled	4	4	16	Critical	Antivirus	Block USB, whitelist devices	A.8.10

Risk ID	Asset	Threat	Vulnerability	Likelihood	Impact	Score	Risk Level	Existing Controls	Recommended Treatment	Annex A Controls
RA-17	Printer (MFP)	Document exposure	No secure print-release	2	3	6	Medium	Manual checks	Implement secure print-release	A.7.4
RA-18	Vendor Accounts	Social engineering	No verification protocol	3	4	12	High	Manual approval	Mandatory callback verification	A.6.3
RA-19	CCTV System	Footage loss / tampering	Low retention	2	3	6	Medium	Local NVR	Increase retention, offsite backup	A.7.4
RA-20	Staff Email	Email compromise	No MFA	4	4	16	Critical	Password only	Enforce MFA	A.9.4
RA-21	Exam Papers	Data leakage	Poor physical security	4	5	20	Critical	Locked cabinet	Secure cabinets, restricted access, digitization	A.7.4, A.8.28
RA-22	Lab PCs	Student misuse	Unrestricted student access	4	4	16	Critical	Limited monitoring	User restrictions, logging, lab policies	A.5.18, A.8.16
RA-23	System Logs	Undetected incidents	Logs not reviewed	3	4	12	High	Basic logs	Monthly log reviews	A.8.14
RA-24	Lab Software	Software piracy / risks	Unlicensed software	3	4	12	High	Partial inventory	Enforce licensing & audit tools	A.8.9, A.5.10